

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ KỸ THUẬT TP. HCM
KHOA CÔNG NGHỆ THÔNG TIN



HCMUTE

HỆ THỐNG GIÁM SÁT AN TOÀN MẠNG
BÁO CÁO LAB-04
HỌC KỲ 2/2025-2026
GVHD: TS. Huỳnh Nguyên Chính
MÃ HP: NSMS432280
SVTH: Dương Khánh Duy-23162010

TPHCM, Tháng 6 Năm 2026

Mục Lục

I. GIỚI THIỆU	3
1.1. Mục tiêu bài thực hành	3
1.2. Tổng quan ngắn về SIEM và Splunk	3
II. MÔ HÌNH TRIỂN KHAI	4
2.1. Kiến trúc hệ thống	4
2.2. Quy trình xử lý	4
III. CÀI ĐẶT VÀ CẤU HÌNH SPLUNK	5
3.1. Cài đặt Splunk Enterprise	5
3.2. Tạo index finova_web	6
3.3. Tạo sourcetype finova:web:access	7
3.4. Nạp dữ liệu qua Splunk Web	7
IV. THU THẬP VÀ CHUẨN HÓA LOG	9
4.1. Kiểm tra dữ liệu đầu vào	9
4.2. Trích xuất trường dữ liệu	9
V. TÌM KIẾM VÀ PHÂN TÍCH DỮ LIỆU	11
5.1. Tìm kiếm toàn bộ log	11
5.2. Phân tích HTTP Status	11
5.3. Phân tích Top URI	12
5.4. Phân tích Top User-Agent	12
5.5. Phân tích Top Client IP	12
5.6. Phân tích lưu lượng theo thời gian	13
VI. TRỰC QUAN HÓA KẾT QUẢ	14
6.1. Lựa chọn loại biểu đồ	14
6.2. Các biểu đồ đã tạo	14
VII. XÂY DỰNG ALERT PHÁT HIỆN SQL INJECTION	15
7.1. Điều kiện phát hiện	15
7.2. Lưu truy vấn thành Alert	15
7.3. Kiểm tra trạng thái Alert	16
VIII. ĐÁNH GIÁ KẾT QUẢ	17
8.1. Chức năng đã thực hiện	17
8.2. Kết quả an toàn thông tin đáng chú ý	17
8.3. Hạn chế	17
IX. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	18
TÀI LIỆU THAM KHẢO	Error! Bookmark not defined.

I. GIỚI THIỆU

1.1. Mục tiêu bài thực hành

Bài thực hành triển khai Splunk Enterprise để thu thập, lưu trữ và phân tích log truy cập Web. Trọng tâm của bài là kiểm tra dữ liệu đầu vào, trích xuất trường, viết truy vấn SPL, trực quan hóa kết quả và tạo cảnh báo cho hành vi có dấu hiệu SQL Injection.

Sau khi hoàn thành bài thực hành, sinh viên có thể:

- Tạo index và sourcetype riêng cho dữ liệu Web.
- Nạp dữ liệu vào Splunk và kiểm tra sự kiện đã được ghi nhận.
- Phân tích HTTP status, URI, User-Agent, địa chỉ IP và lưu lượng theo thời gian.
- Tạo visualization và cấu hình alert theo điều kiện phát hiện.

1.2. Tổng quan ngắn về SIEM và Splunk

SIEM là hệ thống tập trung log từ nhiều nguồn, hỗ trợ tìm kiếm, phân tích, tương quan sự kiện và cảnh báo. Splunk Enterprise cung cấp các chức năng cần thiết cho bài lab gồm Index, Sourcetype, Search Processing Language (SPL), Visualization và Alert.

II. MÔ HÌNH TRIỂN KHAI

2.1. Kiến trúc hệ thống

Luồng thu thập và phân tích dữ liệu



Hình 1. Luồng thu thập và phân tích dữ liệu trong bài lab

Trong phạm vi bài thực hành, dữ liệu được nạp từ tệp mẫu qua Splunk Web. Đây là hình thức upload dữ liệu tĩnh, không phải cơ chế giám sát liên tục bằng Universal Forwarder hoặc Data Input kiểu Monitor.

2.2. Quy trình xử lý

Bước 1. Chuẩn bị tệp dữ liệu Web.

Bước 2. Tạo index finova_web.

Bước 3. Tạo sourcetype finova:web:access.

Bước 4. Nạp tệp dữ liệu vào Splunk.

Bước 5. Trích xuất các trường cần phân tích.

Bước 6. Chạy truy vấn SPL và tạo biểu đồ.

Bước 7. Lưu truy vấn phát hiện thành Alert.

III. CÀI ĐẶT VÀ CẤU HÌNH SPLUNK

3.1. Cài đặt Splunk Enterprise

Ảnh thực hành cho thấy Splunk được cài đặt trên macOS. Báo cáo sử dụng đúng môi trường này để bảo đảm nội dung và hình minh họa thống nhất.

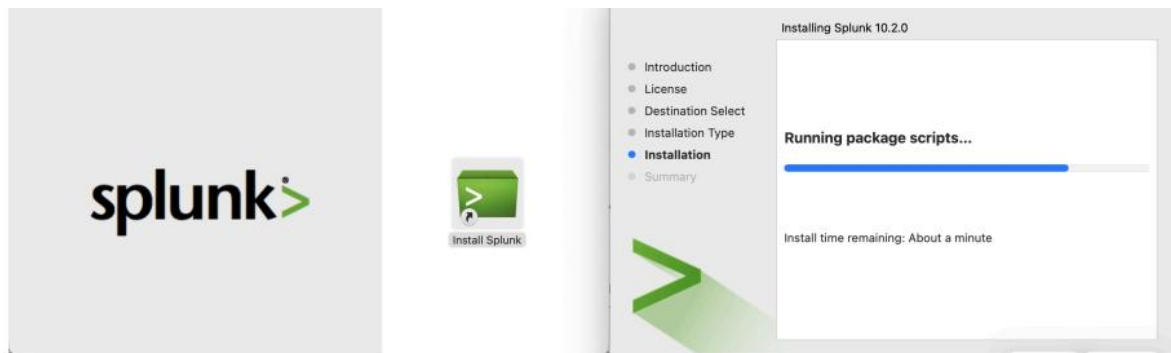
Bước 1. Tải bộ cài Splunk Enterprise phù hợp với macOS.

Bước 2. Mở bộ cài và thực hiện các bước theo trình hướng dẫn.

Bước 3. Chấp nhận điều khoản sử dụng.

Bước 4. Tạo tài khoản quản trị và khởi động Splunk.

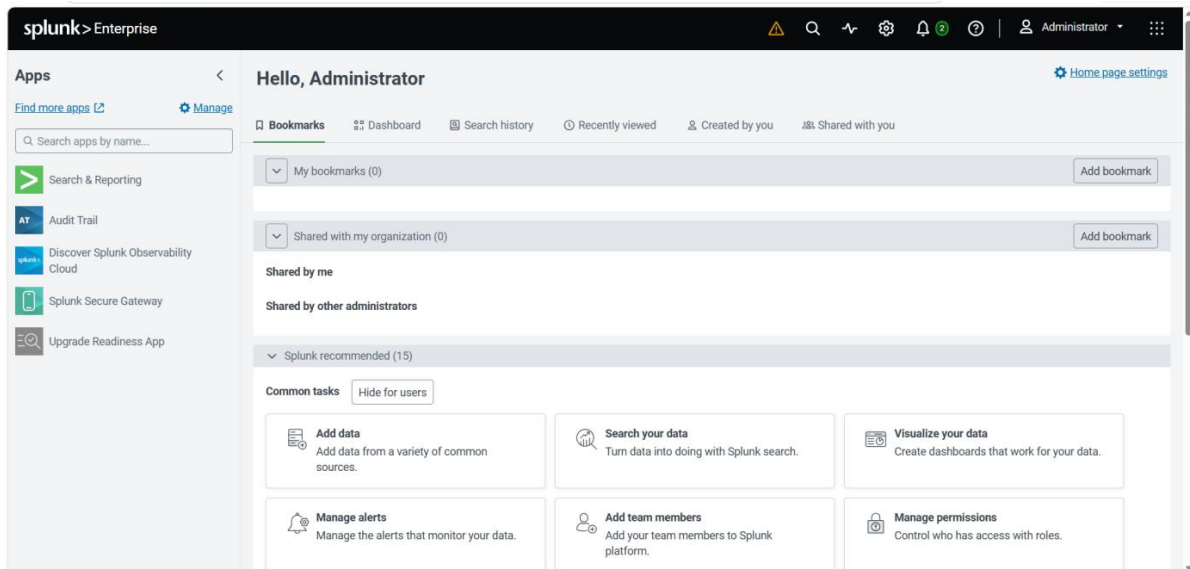
Bước 5. Truy cập <http://localhost:8000> và đăng nhập.



Hình 2. Cài đặt Splunk Enterprise

```
Third Party Products: As set out in section 13.3.
Third Party Providers: Your authorized consultants, contractors, and agents.
Trial Offering: An Offering we make available on a trial or evaluation basis.
Usage Data: Data generated from the usage, configuration, deployment, access,
and performance of an Offering.
Use Rights: As set out in section 1.1.
[Do you agree with this license? [y/n]: y ]
This appears to be your first time running this version of Splunk.
Splunk software must create an administrator account during startup. Otherwise,
you cannot log in.
Create credentials for the administrator account.
Characters do not appear on the screen when you type in credentials.
[Please enter an administrator username: admin ]
Password must contain at least:
  * 8 total printable ASCII character(s).
Please enter a new password:
```

Hình 3. Khởi tạo tài khoản quản trị trong Terminal



Hình 4. Giao diện Splunk Enterprise sau khi đăng nhập

3.2. Tạo index finova_web

Bước 1. Mở Settings và chọn Indexes.

Bước 2. Chọn New Index.

Bước 3. Nhập tên finova_web, giữ loại dữ liệu Events.

Bước 4. Lưu cấu hình và kiểm tra index trong danh sách.

Add new index

*Name

finova_web

*Index data type

☒ Events
 ☐ Metrics

The type of data to store (event-based or metrics)

Home path

Hot/warm db path. Leave blank for default (\$SPLUNK_DB/INDEX_NAME/db).

Cold path

Cold db path. Leave blank for default (\$SPLUNK_DB/INDEX_NAME/colddb).

Thawed path

Thawed/resurrected db path. Leave blank for default (\$SPLUNK_DB/INDEX_NAME/thaweddb).

*Data integrity check

☐ Enable
 ☒ Disable

Enable this if you want Splunk to compute hashes on every slice of your data for the purpose of data integrity.

*Max size of entire index

5

GB

Cancel

Save

Hình 5. Nhập thông tin index finova_web

Name	Status	Type	App	Current Size	Max Size	Oldest Event	Surface Event	Latest Event	Home Path	Parsed Path
finova_web	Active	Events	system	1.9GB	480.38 GB	12	17 hours ago	on hour ago	\$SPLUNK_DB/finova_web	-
finova_audit	Active	Events	search	2.9GB	900 GB	14,396	5 months ago	5 months ago	\$SPLUNK_DB/finova_audit	-
finova_lab	Active	Events	search	1.9GB	5 GB	120	6 months ago	4 months ago	\$SPLUNK_DB/finova_lab	-
finova_logs	Active	Events	search	4.4GB	900 GB	25,000	5 months ago	17 hours ago	\$SPLUNK_DB/finova_logs	-
finova_metrics	Active	Events	search	9.0GB	900 GB	14,646	5 months ago	5 months ago	\$SPLUNK_DB/finova_metrics	-
indexes	Active	Events	system	1.9GB	480.38 GB	0	-	-	\$SPLUNK_DB/finova_indexes	-

Hình 6. Index finova_web trong danh sách

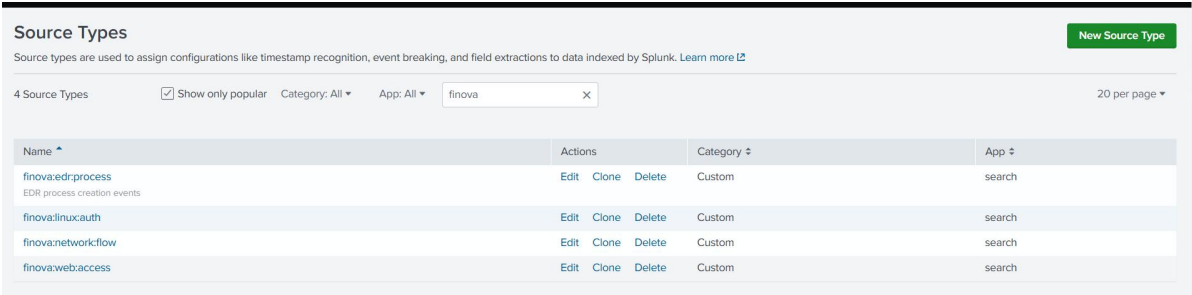
3.3. Tạo sourcetype finova:web:access

Bước 1. Mở Settings và chọn Source types.

Bước 2. Chọn New Source Type.

Bước 3. Nhập tên finova:web:access.

Bước 4. Lưu cấu hình để sử dụng khi nạp dữ liệu Web.



Hình 7. Danh sách sourcetype của hệ thống

3.4. Nạp dữ liệu qua Splunk Web

Bước 1. Chuẩn bị tệp finova_web.json trong thư mục dữ liệu.

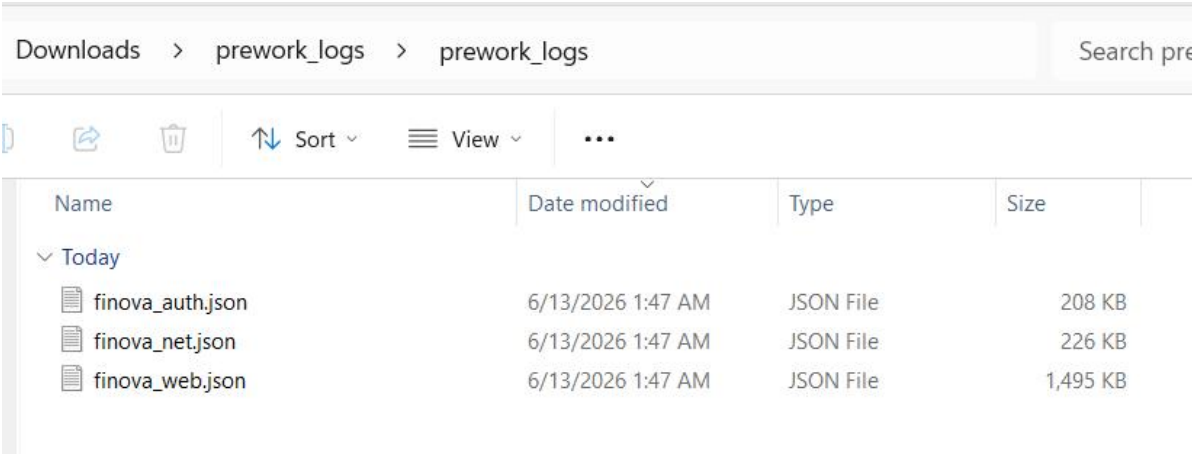
Bước 2. Mở Settings, chọn Add Data.

Bước 3. Chọn Upload và chọn tệp finova_web.json.

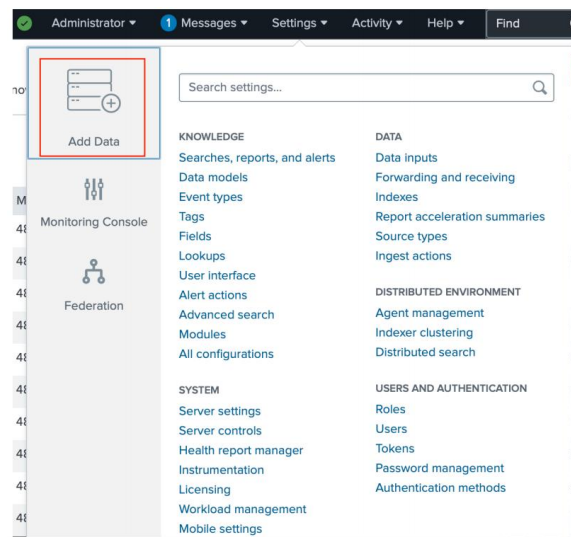
Bước 4. Tại bước Set Source Type, chọn finova:web:access.

Bước 5. Tại Input Settings, chọn index finova_web.

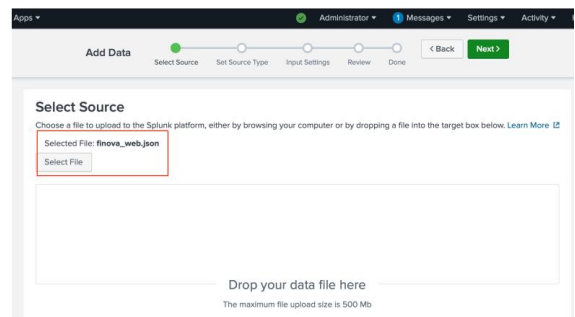
Bước 6. Kiểm tra cấu hình và hoàn tất quá trình upload.



Hình 8. Các tệp dữ liệu được sử dụng trong bài lab



Hình 9. Mở chức năng Add Data



Hình 10. Chọn tệp finova_web.json

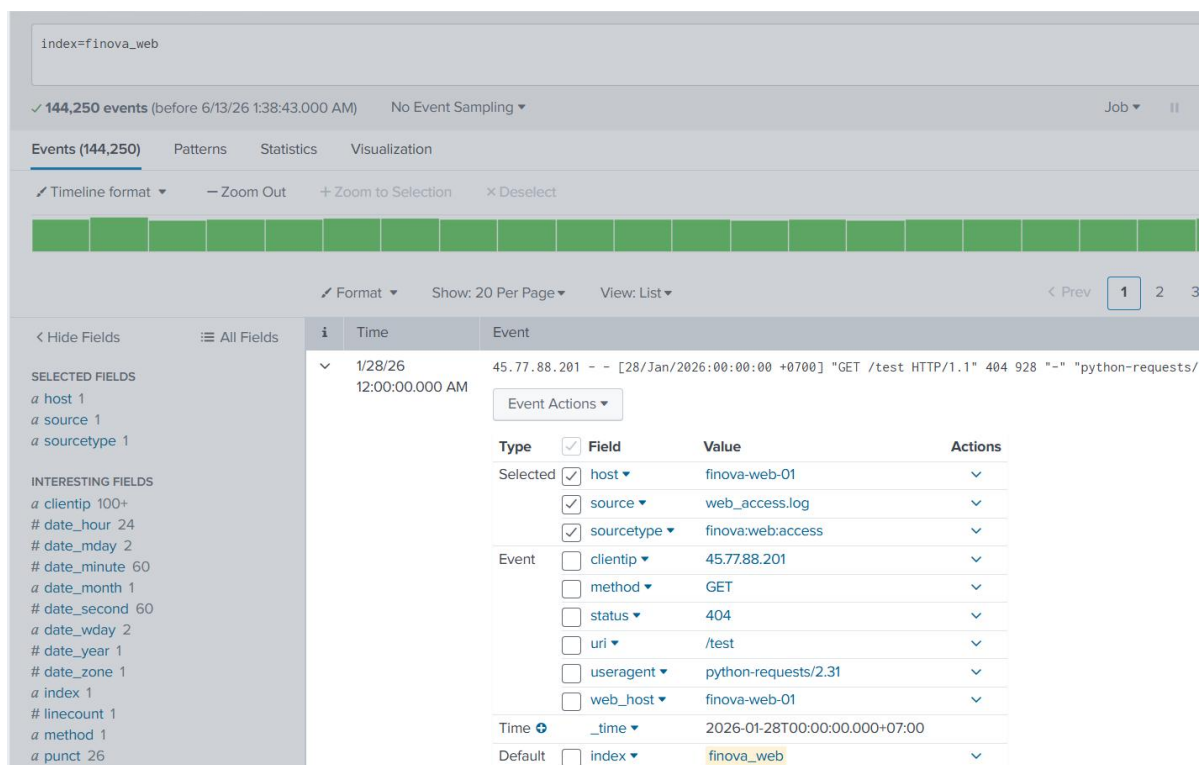
IV. THU THẬP VÀ CHUẨN HÓA LOG

4.1. Kiểm tra dữ liệu đầu vào

Chạy truy vấn sau trong Search & Reporting:

index=finova_web

Splunk trả về 144.250 sự kiện. Mỗi sự kiện có thời gian, host, source, sourcetype và nội dung log gốc.



Hình 11. Kiểm tra sự kiện trong index finova_web

4.2. Trích xuất trường dữ liệu

Các trường clientip, method, uri, status, useragent và web_host được trích xuất từ nội dung access log. Việc đặt tên trường rõ ràng giúp các truy vấn sau ngắn và dễ kiểm tra.

Bước 1. Mở Settings, chọn Fields, sau đó chọn Field Extractions.

Bước 2. Tạo Field Extraction cho sourcetype finova:web:access.

Bước 3. Khai báo biểu thức nhận dạng các trường cần thiết.

Bước 4. Lưu cấu hình và kiểm tra trạng thái Active.

Fields / Field extractions

Field extractions

New Field Extraction

Open Field Extractor

Q Search...

App

Search & Reporting (sea...

Configuration Source

Visible in the App

Owner

Any

10 per page

2

of 5 pages

<

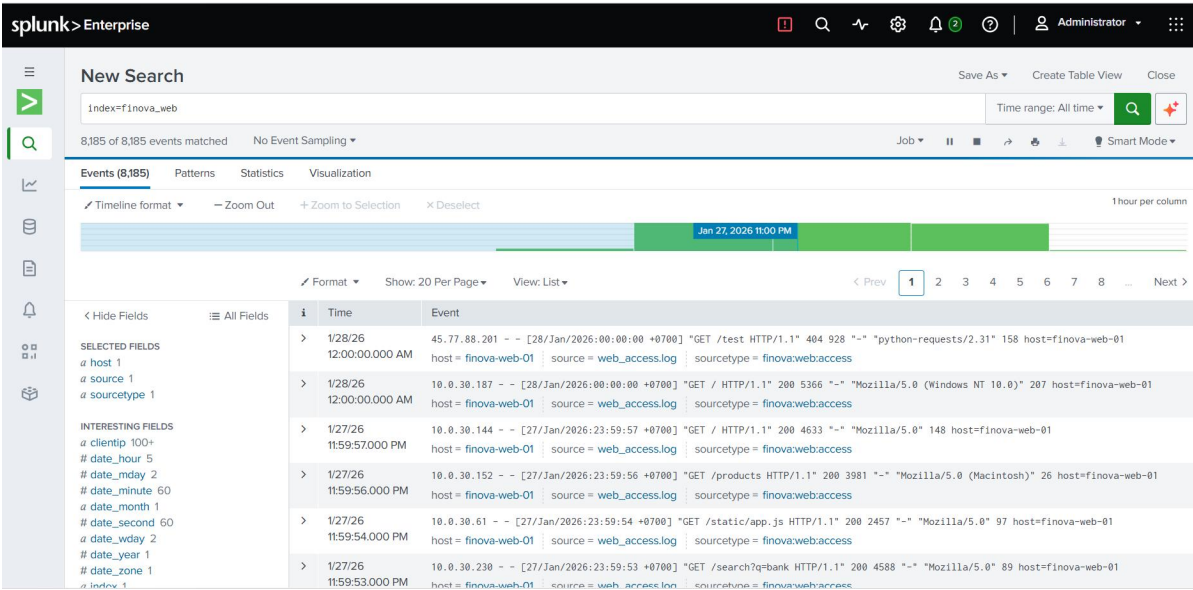
>

Name ↕	Status ↕	Type ↕	Extraction/Transform ↕	Owner ↕	App ↕	Sharing ↕	
finova:web.access : EXTRACT: clientip.method.uri.status.useragent.web_host	● Active	Inline	^(?P<clientip>[^\s]+\n)*(?P<method>[^\s]+)\s+(?P<uri>[^\s]+\w+/\d+\n)\s+(?P<status>\d+)\s+(?P<useragent>[^\s]+)\n*(?P<web_host>.+)	khanhduy	search	Private	⋮
linux_messages_syslog : REPORT:syslog	● Active	Uses transform	syslog-extractions	No owner	system	Global	⋮
linux_secure : REPORT:syslog	● Active	Uses transform	syslog-extractions	No owner	system	Global	⋮
osx_asl : REPORT:asl	● Active	Uses transform	bracket-space	No owner	system	Global	⋮
PerformanceMonitor : REPORT:MESSAGE	● Active	Uses transform	perfmon-kv	No owner	system	Global	⋮
postfix_syslog : REPORT:syslog	● Active	Uses transform	syslog-extractions	No owner	system	Global	⋮
scheduler : EXTRACT:fields	● Active	Inline	(?i)^(?!\s+)(2 ?[:+~]\d+)?(?P<log_level>[^\s]+)\s+(?P<component>[^\s]+) - (?P<event_message>.+)	No owner	search	Global	⋮

Hình 12. Field Extraction với owner khanhduy

V. TÌM KIẾM VÀ PHÂN TÍCH DỮ LIỆU

5.1. Tìm kiếm toàn bộ log



Hình 13. Danh sách sự kiện trong index finova_web

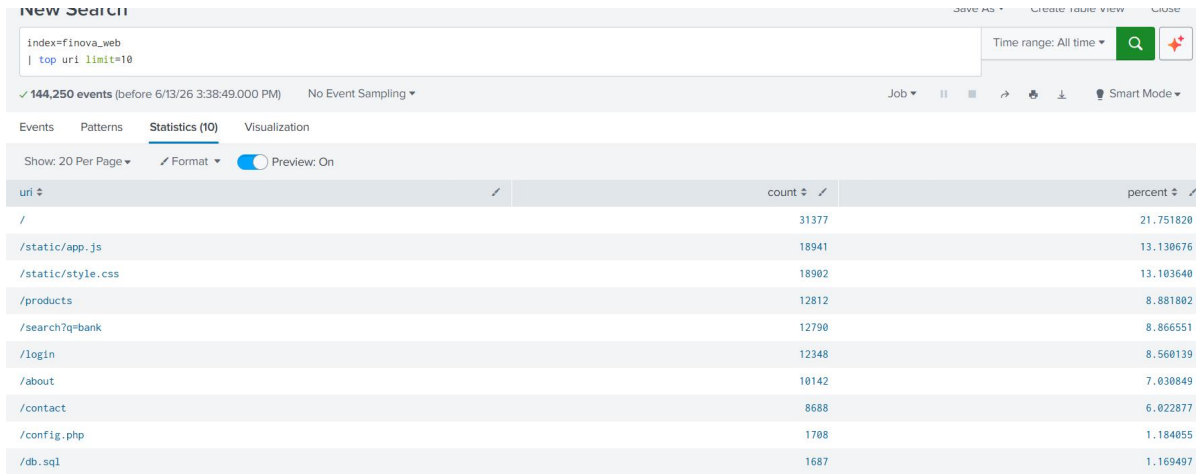
5.2. Phân tích HTTP Status



Hình 14. Thống kê số lượng sự kiện theo HTTP status

Kết quả gồm 125.250 phản hồi 200 và 19.000 phản hồi 404. Tỷ lệ 404 xấp xỉ 13,17%, đủ lớn để cần kiểm tra các URI bị truy cập sai hoặc bị dò quét. Vì vậy không nên chỉ dựa vào số lượng 200 để kết luận hệ thống hoàn toàn ổn định.

5.3. Phân tích Top URI

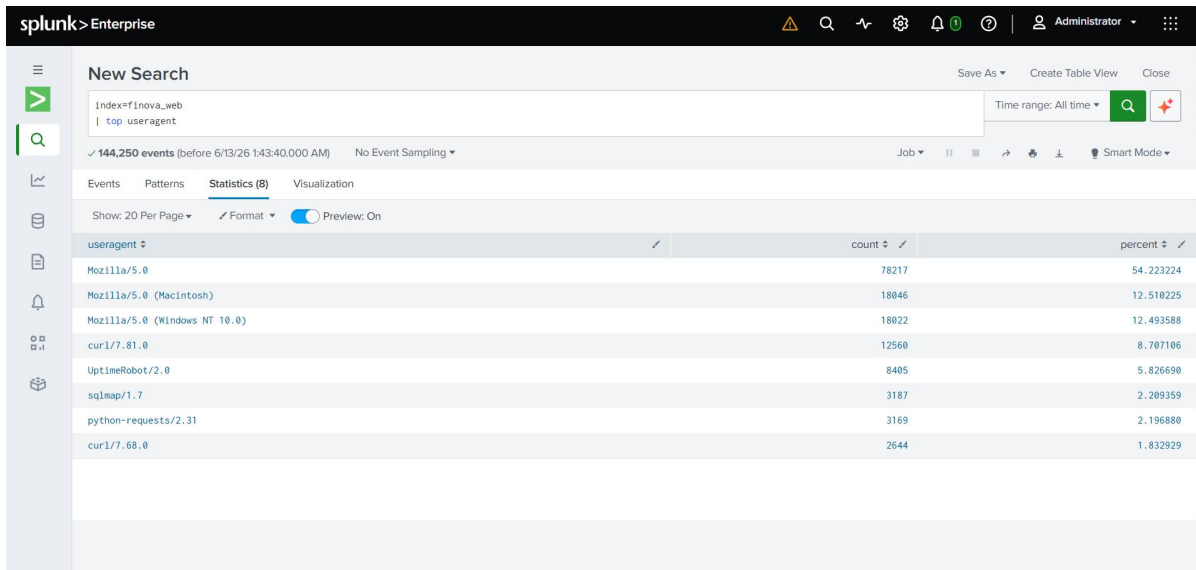


uri	count	percent
/	31377	21.751820
/static/app.js	18941	13.130676
/static/style.css	18902	13.103640
/products	12812	8.881802
/search?q=bank	12790	8.866551
/login	12348	8.560139
/about	10142	7.030849
/contact	8688	6.022877
/config.php	1708	1.184055
/db.sql	1687	1.169497

Hình 15. Mười URI được truy cập nhiều nhất

Các tài nguyên phổ biến gồm /, /static/app.js, /static/style.css, /products và /login. Danh sách cũng xuất hiện /config.php và /db.sql. Đây là các đường dẫn nhạy cảm, thường được công cụ tự động dùng để dò tìm tệp cấu hình hoặc cơ sở dữ liệu.

5.4. Phân tích Top User-Agent



useragent	count	percent
Mozilla/5.0	78217	54.223224
Mozilla/5.0 (Macintosh)	18046	12.510225
Mozilla/5.0 (Windows NT 10.0)	18022	12.493588
curl/7.81.0	12560	8.707106
UptimeRobot/2.0	8405	5.826690
sqlmap/1.7	3187	2.209359
python-requests/2.31	3169	2.196880
curl/7.68.0	2644	1.832929

Hình 16. Thống kê User-Agent

Mozilla chiếm phần lớn lưu lượng. Tuy nhiên dữ liệu còn có curl, python-requests và sqlmap. Các User-Agent này không đồng nghĩa chắc chắn là tấn công, nhưng là chỉ báo cần kết hợp với URI, status và tần suất truy cập để điều tra.

5.5. Phân tích Top Client IP

New Search Save As Create Table View Close

index=finova_web
| top clientip limit=10

Time range: All time Q +

✓ 144,250 events (before 6/13/26 3:40:24.000 PM) No Event Sampling Job || ■ → ⌵ ⌴ Smart Mode

Events Patterns **Statistics (10)** Visualization

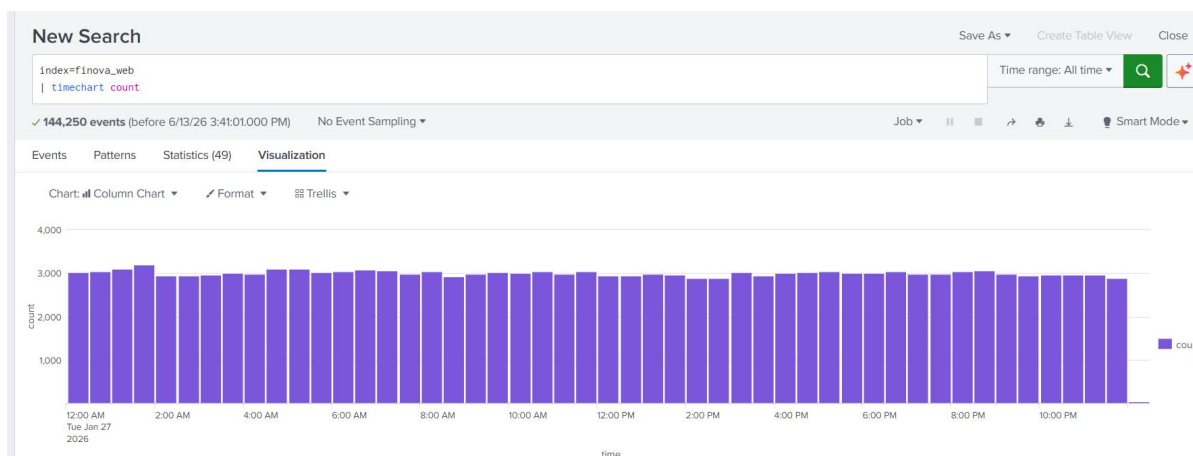
Show: 20 Per Page ✓ Format Preview: On

clientip	count	percent
45.77.88.201	9000	6.239168
10.0.10.10	9000	6.239168
10.0.10.50	6000	4.159445
10.0.30.222	545	0.377816
10.0.30.207	545	0.377816
10.0.30.191	541	0.375043
10.0.30.70	524	0.363258
10.0.30.132	520	0.360485
10.0.30.48	518	0.359099
10.0.30.8	517	0.358406

Hình 17. Các địa chỉ IP có số lượng truy cập cao

Hai địa chỉ 45.77.88.201 và 10.0.10.10 đều có khoảng 9.000 yêu cầu. Các địa chỉ có lưu lượng cao cần được phân tích thêm theo URI và User-Agent để phân biệt người dùng hợp lệ với hoạt động tự động.

5.6. Phân tích lưu lượng theo thời gian



Hình 18. Biểu đồ lưu lượng truy cập theo thời gian

Lưu lượng trong ảnh tương đối đều, dao động quanh mức 3.000 sự kiện cho mỗi khoảng thời gian. Không quan sát thấy đỉnh tăng đột biến rõ ràng trong phạm vi dữ liệu hiển thị.

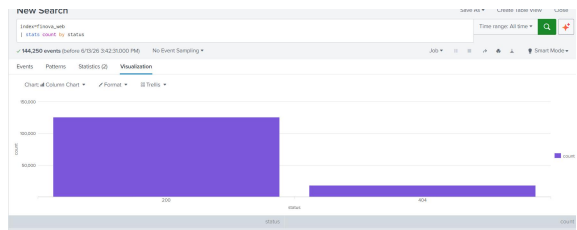
VI. TRỰC QUAN HÓA KẾT QUẢ

6.1. Lựa chọn loại biểu đồ

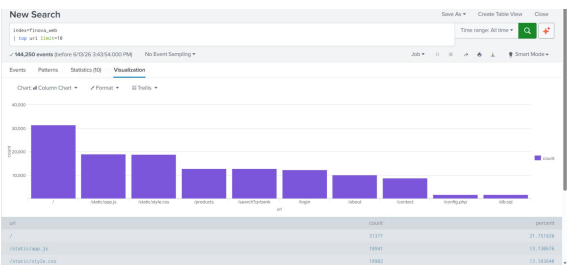
Nội dung	Truy vấn	Loại biểu đồ phù hợp
HTTP Status	stats count by status	Column Chart
Top URI	top uri limit=10	Column Chart
Top User-Agent	top useragent limit=10	Pie Chart
Traffic Trend	timechart count	Column Chart theo ảnh thực hành

Tên loại biểu đồ trong phần này được ghi theo đúng hình thực hành, tránh tình trạng mô tả Pie Chart nhưng hình lại là Column Chart.

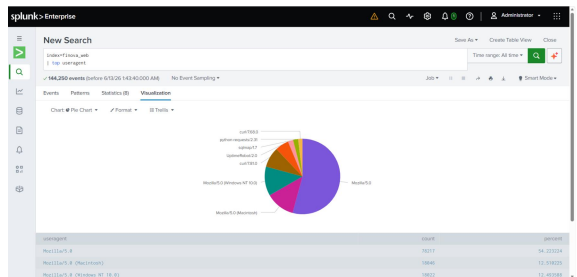
6.2. Các biểu đồ đã tạo



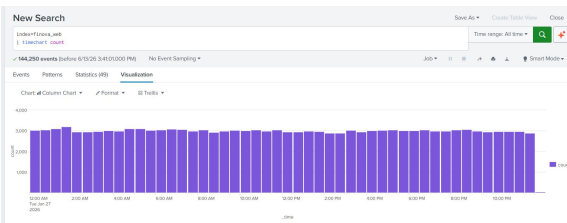
Hình 19. Column Chart cho HTTP Status



Hình 20. Column Chart cho Top URI



Hình 21. Pie Chart cho Top User-Agent



Hình 22. Column Chart cho Traffic Trend

VII. XÂY DỰNG ALERT PHÁT HIỆN SQL INJECTION

7.1. Điều kiện phát hiện

Use Case tập trung vào URI sau khi giải mã có chuỗi OR 1=1, phản hồi HTTP 200 và lặp lại nhiều lần từ cùng một địa chỉ IP. Truy vấn được điều chỉnh để có đủ điều kiện hành vi và ngưỡng.

```
index=finova_web
| eval decoded_uri=urldecode(uri)
| search decoded_uri="*OR 1=1*" status=200
| stats count AS request_count values(decoded_uri) AS uri_sample by clientip
| where request_count >= 5
```

Ngưỡng năm yêu cầu giúp giảm cảnh báo từ một sự kiện đơn lẻ. Trong môi trường thực tế, ngưỡng cần được hiệu chỉnh theo lưu lượng bình thường của hệ thống.

7.2. Lưu truy vấn thành Alert

Bước 1. Chạy truy vấn và kiểm tra kết quả với khoảng thời gian All time.

Bước 2. Chọn Save As, sau đó chọn Alert.

Bước 3. Đặt tên [khanhduy] - UC1 - SQL Injection Attempt.

Bước 4. Chọn Scheduled và chạy mỗi 5 phút.

Bước 5. Đặt Trigger khi Number of Results lớn hơn 0.

Bước 6. Bật throttle 5 phút để hạn chế cảnh báo lặp.

Bước 7. Lưu cấu hình.

Edit Alert

×

Settings

Alert

[khanhduy] – UC1 – SQL Injection Attempt

Description

Optional

Alert type

Scheduled

Real-time

Run on Cron Schedule ▾

Time Range

Last 5 minutes ▸

Cron Expression

*/5 * * * *

e.g. 00 18 *** (every day at 6PM). [Learn More](#)

Expires

24

hour(s) ▾

Trigger Conditions

Trigger alert when

Number of Results ▾

is greater than ▾

0

Trigger

Once

For each result

Throttle ?

☒

Suppress triggering for

5

minute(s) ▾

Trigger Actions

+ Add Actions ▾

Cancel

Save

Hình 24. Cấu hình Alert SQL Injection

7.3. Kiểm tra trạng thái Alert

[khanhduy] – UC1 – SQL Injection Attempt

Enabled: Yes. [Disable](#)

App: finova_lab_7

Permissions: Shared in App. Owned by admin. [Edit](#)

Modified: 29 Jan 2026 21:19:09

Alert Type: Scheduled. Cron Schedule. [Edit](#)

Trigger Condition: .. Number of Results is > 0. [Edit](#)

Actions: 2 Actions

Add to Triggered Alerts

Send email

[Edit](#)

ⓘ

There are no fired events for this alert.

Hình 25. Thông tin Alert sau khi lưu

Alert đã được bật và có hai hành động: ghi vào Triggered Alerts và gửi email. Trang chi tiết hiển thị There are no fired events for this alert. Nguyên nhân hợp lý là dữ liệu được upload có thời gian lịch sử, trong khi Alert chỉ tìm kiếm Last 5 minutes.

VIII. ĐÁNH GIÁ KẾT QUẢ

8.1. Chức năng đã thực hiện

- Cài đặt và truy cập Splunk Enterprise.
- Tạo index và sourcetype riêng.
- Nạp 144.250 sự kiện Web.
- Trích xuất các trường phục vụ phân tích.
- Thực hiện truy vấn Search, Stats, Top và Timechart.
- Tạo visualization và lưu Alert SQL Injection.

8.2. Kết quả an toàn thông tin đáng chú ý

Quan sát	Nhận định
19.000 phản hồi 404	Tỷ lệ khoảng 13,17%; cần xem xét hoạt động dò quét.
/config.php và /db.sql xuất hiện	Có dấu hiệu truy cập các tệp nhạy cảm.
Có sqlmap, curl, python-requests	Có thể là công cụ tự động hoặc kiểm thử bảo mật.
Một số IP có lưu lượng cao	Cần tương quan với URI, status và User-Agent.
Alert chưa có fired event	Phù hợp với việc tìm kiếm 5 phút trên dữ liệu lịch sử.

8.3. Hạn chế

- Dữ liệu được upload từ tệp mẫu, chưa thu thập liên tục từ Web Server.
- Chưa tương quan Web log với Auth log, EDR log và Network log.
- Chưa có bằng chứng Alert được kích hoạt bởi sự kiện thời gian thực.
- Các ngưỡng phát hiện mới ở mức thử nghiệm, chưa được hiệu chỉnh theo baseline.

IX. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

Bài lab đã hoàn thành quy trình cơ bản của một hệ thống SIEM trên Splunk: nạp log, chuẩn hóa trường, tìm kiếm, thống kê, trực quan hóa và cấu hình cảnh báo. Kết quả cho thấy dữ liệu có các chỉ báo cần quan tâm như tỷ lệ 404 cao, truy cập URI nhạy cảm và sự xuất hiện của User-Agent tự động.

Hướng phát triển.

- Thu thập log liên tục bằng Splunk Universal Forwarder.
- Kết hợp Web, Authentication, EDR và Network log để tương quan sự kiện.
- Xây dựng baseline và điều chỉnh ngưỡng Alert.
- Tích hợp MITRE ATT&CK để phân loại kỹ thuật tấn công.
- Kiểm thử Email Alert và quy trình phản ứng sự cố.